



PERFORMANCE WORK STATEMENT (PWS) DEPARTMENT OF VETERANS AFFAIRS

**Office of Information & Technology
Produce Delivery Service (PDS)**

eDiscovery Software as a Service (SaaS) & Maintenance

**Date: 03/10/2026
VA-26-00011700**

PWS Version Number: 1.0

Contents

1.0	BACKGROUND	4
2.0	APPLICABLE DOCUMENTS	4
3.0	SCOPE OF WORK	6
4.0	PERFORMANCE DETAILS	6
4.1	PERFORMANCE PERIOD	6
4.2	PLACE OF PERFORMANCE	7
4.3	TRAVEL	8
5.0	SPECIFIC TASKS AND DELIVERABLES	8
5.1	SaaS FEDRAMP ASSESSMENT AND AUTHORIZATION AND CONTINUOUS MONITORING REQUIREMENTS	8
5.1.1	IF THE SOLUTION IS FedRAMP AUTHORIZED BUT NOT VA AUTHORIZED 8	
5.1.2	IF THE SOLUTION IS FedRAMP AUTHORIZED AND VA AUTHORIZED:..9	
5.2	SPECIFIC TASKS AND DELIVERABLES	10
5.2.1	CONTRACTOR PROJECT MANAGEMENT PLAN	10
5.2.2	PRIVACY & HIPAA TRAINING	10
5.2.3	TECHNICAL KICKOFF MEETING	11
5.3	COMMERCIAL-OFF-THE-SHELF (COTS) EDISCOVERY PRODUCT	11
5.4	EDISCOVERY IMPLEMENTATION	17
5.4.1	REQUIREMENTS	17
5.4.2	DESIGN	17
5.4.3	CONFIGURATION & IMPLEMENTATION	18
5.4.4	PROVIDE NETWORK CONNECTIVITY	18
5.4.5	TEST & EVALUATION (T & E)	19
5.4.6	MONTHLY REPORTING	19
5.5	EDISCOVERY TRAINING	20
5.6	EDISCOVERY SUPPORT	20
5.7	ASSESSMENT, AUTHORIZATION, AND CONTINUOUS MONITORING	21
5.8	MIGRATION TASKS	23
5.9	OPTIONAL TASKS	23
5.9.1	OUTGOING TRANSITION SUPPORT (OPTIONAL TASK 1)	23
5.9.2	ADDITIONAL STORAGE (OPTIONAL TASK 2)	25
5.9.3	ADDITIONAL CONCURRENT USERS (OPTIONAL TASK 3)	25
6.0	GENERAL REQUIREMENTS	25

6.1	ENTERPRISE AND IT FRAMEWORK	25
6.1.1	VA TECHNICAL REFERENCE MODEL	25
6.1.2	ZERO TRUST – VA CRITICAL SECURITY CONTROLS	25
6.1.3	FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM) 25	
6.1.4	INTERNET PROTOCOL VERSION 6 (IPv6)	27
6.1.5	TRUSTED INTERNET CONNECTION (TIC)	27
6.1.6	STANDARD COMPUTER CONFIGURATION	27
6.1.7	VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)	28
6.1.8	PROCESS ASSET LIBRARY (PAL)	29
6.1.9	AUTHORITATIVE DATA SOURCES	29
6.1.10	SOCIAL SECURITY NUMBER (SSN) REDUCTION	30
6.2	SECURITY AND PRIVACY REQUIREMENTS	30
6.2.1	POSITION/TASK RISK DESIGNATION LEVEL(S)	30
6.2.2	CONTRACTOR PERSONNEL SECURITY REQUIREMENTS	31
6.3	METHOD AND DISTRIBUTION OF DELIVERABLES	33
6.4	PERFORMANCE METRICS	33
6.5	FACILITY/RESOURCE PROVISIONS	34
ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE		40

1.0 BACKGROUND

The Department of Veterans Affairs (VA), Office of Information & Technology (OIT), Product Delivery Services (PDS), strives to provide high quality, effective, and efficient Information Technology (IT) services to those responsible for providing care to the Veterans at the point-of-care as well as throughout all the points of the Veterans' health care in an effective, timely and compassionate manner. VA depends on Information Management/Information Technology (IM/IT) systems to meet mission goals.

The VA Office of General Counsel (OGC) and Office of Accountability and Whistleblower Protection (OAWP) require an eDiscovery system to effectively preserve, collect, process, review, analyze, and produce Electronically Stored Information (ESI) in compliance with legal obligations under the Federal Rules of Civil Procedure (FRCP).

VA OGC requires the capability to meet time sensitive requests to process, upload and analyze millions of ESI records as required to meet time sensitive court-ordered deadlines for productions in litigation, investigations, Freedom of Information Act (FOIA) requests, and Congressional Oversight requests to minimize risks of court sanctions and costly unmerited settlements.

2.0 APPLICABLE DOCUMENTS

In the performance of the tasks associated with this Performance Work Statement, the Contractor shall comply with the following:

1. Public Law 109-461, Veterans Benefits, Health Care, and Information Technology Act of 2006, Title IX, Information Security Matters
2. 42 U.S.C. § 2000d, "Title VI of the Civil Rights Act of 1964," as amended
3. VA Directive 0710, "Personnel Security and Suitability Program," June 4, 2010
<https://www.va.gov/vapubs/index.cfm>
4. VA Handbook 0710, "Personnel Security and Suitability Program," May 2, 2016
<https://www.va.gov/vapubs/index.cfm>
5. 36 C.F.R. Part 1194, "Information and Communication Technology Standards and Guidelines," as amended
6. OMB Circular A-130, "Managing Federal Information as a Strategic Resource," July 28, 2016
7. NIST SP 800-66 Rev. 2, "Implementing the HIPAA Security Rule," February 2024
8. 45 C.F.R Parts 160 and 164 (HIPAA Privacy and Security Rules)
9. Sections 504 and 508 of the Rehabilitation Act (29 U.S.C. § 794d), as amended
10. Homeland Security Presidential Directive 12 (HSPD-12), August 27, 2004
11. VA Directive 6500, "VA Cybersecurity Program," February 24, 2021
(Includes VA Notice 24-18 and VA Notice 25-07)
12. VA Handbook 6500, "Risk Management Framework for VA Information Systems," February 24, 2021
(Includes VA Notice 25-01 and VA Notice 25-06)
13. NIST SP 800-37 Rev. 2, "Risk Management Framework for Information Systems," December 2018

14. NIST SP 800-53 Rev. 5, "Security and Privacy Controls for Federal Information Systems and Organizations," 2020
15. VA Memorandum, VAIQ #7100147, "Continued Implementation of HSPD-12," April 29, 2011
<https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>
16. IAM Identity Management Business Requirements Guidance (2013)
<https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>
17. Federal Identity, Credential, and Access Management (FICAM) Architecture, June 30, 2023
<https://www.idmanagement.gov/arch/>
18. NIST SP 800-63-3, 800-63A, 800-63B, 800-63C, "Digital Identity Guidelines," March 02, 2020
19. NIST SP 800-157, "Guidelines for Derived PIV Credentials," December 2014
20. VA Memorandum, "PIV Logical Access Policy Clarification," July 17, 2019
<https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>
21. Trusted Internet Connections (TIC) 3.0 Core Guidance Documents
<https://www.cisa.gov/publication/tic-30-core-guidance-documents>
22. OMB Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative," September 12, 2019
23. OMB Memorandum M-08-23, "Securing the Federal Government's Domain Name System Infrastructure," August 22, 2008
24. Executive Order 14028, "Executive Order on Improving the Nation's Cybersecurity"
<https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2025/01/16/executive-order-on-strengthening-and-promoting-innovation-in-the-nations-cybersecurity/>
25. OMB Memorandum M-22-09, "Moving the U.S. Government Toward Zero Trust Cybersecurity Principles," January 26, 2022
<https://www.whitehouse.gov/wp-content/uploads/2022/01/M-22-09.pdf>
26. NIST SP 800-52 Rev. 2, "Guidelines for the Selection, Configuration, and Use of TLS Implementations"
27. OMB Memorandum M-22-18, "Enhancing the Security of the Software Supply Chain," September 14, 2022
28. OMB Memorandum M-23-16, "Update to Memorandum M-22-18," June 9, 2023
29. OMB Memorandum M-21-31, "Improving the Federal Government's Investigative and Remediation Capabilities Related to Cybersecurity Incidents," August 27, 2021
30. NIST SP 800-88 Rev. 1, "Guidelines for Media Sanitization," December 2014
31. CISA Binding Operational Directive (BOD) 19-02, "Vulnerability Remediation Requirements for Internet-Accessible Systems"
<https://www.cisa.gov/news-events/directives/bod-19-02-vulnerability-remediation-requirements-internet-accessible-systems>
32. CISA BOD 22-01, "Reducing the Significant Risk of Known Exploited Vulnerabilities"
<https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities>
33. CISA BOD 23-01, "Improving Asset Visibility and Vulnerability Detection on Federal Networks"

<https://www.cisa.gov/news-events/directives/bod-23-01-improving-asset-visibility-and-vulnerability-detection-federal-networks>

34. VA Memorandum, "VA Security Controls," January 17, 2025

<https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>

35. NIST SP 500-267B Rev 1, "USGv6 Profile," November 2020

36. OMB Memorandum M-21-07, "Completing the Transition to IPv6," November 19, 2020

3.0 SCOPE OF WORK

The Contractor shall provide an enterprise Software as a Service (SaaS) consisting of a Commercial-off-the-shelf (COTS) product that fully supports VA eDiscovery needs to increase capacity and comply with Federal eDiscovery Law and VA requirements.

The eDiscovery System shall provide the following functions and capabilities to the VA OGC/OAWP eDiscovery needs:

- A SaaS solution authorized at the FedRAMP MODERATE level and meet FISMA Moderate requirements as specified in Section 5.1 at time of proposal submission and fully configurable, deployed and ready for VA use within 14 days of award.
- Implementation of the system, including software installation, data migration, testing, and deployment support.
- Training support shall be available through the duration of the contract period of performance.
- 24/7 on-call technical support.
- Product service and support including technical support and Service Level Agreements (SLAs).
- Installation of software upgrades, patches, and releases.

4.0 PERFORMANCE DETAILS

4.1 PERFORMANCE PERIOD

The period of performance (PoP) shall consist of a 12-month base period plus four (4), 12-month option periods and four (4) optional tasks to be exercised at the Government's discretion and as follows:

- Base period shall include eDiscovery software solution implementation, one-year support of the eDiscovery software, and VA staff training.
- Option Period 1 shall include one-year support of the eDiscovery solution and training for new and updated software modules as released.
- Option Period 2 shall include one-year support of the eDiscovery solution and training for new and updated software modules as released.
- Option Period 3 shall include one-year support of the eDiscovery solution and training for new and updated software modules as released.

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

- Option Period 4 shall include one-year support of the eDiscovery solution and training for new and updated software modules as released.
- Optional Task One – Transition Support: One 90-day optional task for transitional support which may be exercised once at any time during the during the base or option periods (if exercised).

Optional Task Two – Additional Storage: This optional task may be exercised multiple times, and at any time during the base and/or option periods (if exercised) up to 20 times for up to a total of 400TB.

- Optional Task Three - Additional Concurrent Users: This optional task may be exercised multiple times, and at any time during the base and/or option periods (if exercised) up to 18 times for up to a total of 180 Additional Concurrent Users.

There are 11 Federal holidays set by law (USC Title 5 Section 6103) that VA follows:

Under current definitions, five are set by date:

New Year's Day	January 1
Juneteenth	June 19
Independence Day	July 4
Veterans Day	November 11
Christmas Day	December 25

If any of the above falls on a Saturday, then Friday shall be observed as a holiday. Similarly, if one falls on a Sunday, then Monday shall be observed as a holiday.

The other six are set by a day of the week and month:

Martin Luther King's Birthday	Third Monday in January
Washington's Birthday	Third Monday in February
Memorial Day	Last Monday in May
Labor Day	First Monday in September
Columbus Day	Second Monday in October
Thanksgiving	Fourth Thursday in November

4.2 PLACE OF PERFORMANCE

Tasks under this PWS shall be performed at Contractor facilities. The Contractor shall identify the Contractor's place of performance in their proposal submission.

Work may be performed at remote locations with prior approval of the Program Manager (PM). The Contractor shall maintain onsite presence during normal Monday through Friday business hours. After-business-hours, emergency, and pre-approved scheduled work may be performed at remote locations with prior approval of the VA PM as stated in this PWS.

4.3 TRAVEL

The Government does not anticipate travel under this effort to perform the tasks associated with the effort.

5.0 SPECIFIC TASKS AND DELIVERABLES

The Contractor shall perform the specific tasks and deliverables described in the sections that follow.

5.1 SAAS FEDRAMP ASSESSMENT AND AUTHORIZATION AND CONTINUOUS MONITORING REQUIREMENTS

5.1.1 IF THE SOLUTION IS FedRAMP AUTHORIZED BUT NOT VA AUTHORIZED

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA)
2. The Contractor shall remain in compliance with [FedRAMP](#) requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The system must be FedRAMP Authorized at no less than the Moderate impact level.
4. The Contractor shall, where applicable, assist with the VA Authority to Operate (ATO) Process to help achieve agency authorization of the cloud service or migrated application.
5. The Contractor shall provide confirmation of the completion of its FedRAMP System Security Plan (SSP) and supporting documentation by providing, to the VA PM, COR, and DTC, its repository ID number and associated link for VA to download the SSP and all required artifacts within five calendar days of contract award.
6. The Contractor shall work with a VA DTC Subject Matter Expert to develop and provide a VA specific system boundary diagram including any integration and connectivity components for VA use. This will be known as the VA Implementation Diagram (VAID) and will demonstrate the proposed implementation of this system at VA.
7. The Contractor shall provide the results of their most recent Third-Party Assessment Organization (3PAO) Security Assessment Plan (SAP).
8. The Contractor shall complete a 3PAO Security Assessment Report (SAR).
9. The Contractor shall provide VA with the most recent monthly scans for the production environment within the authorization boundary and their scan upload schedule for FedRAMP within 30 calendar days of contract award.
10. The Contractor shall provide their availability to participate in monthly continuous monitoring meetings to be scheduled following successful VA ATO within 30 calendar days of contract award.
11. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall

12. bring the situation to the attention of the other party within one hour in accordance with Addendum B, VA Information and Information System Security/Privacy Language.
13. The Contractor shall comply with FedRAMP data management requirements.
14. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
15. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy.
16. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
17. The Contractor shall provide continuous monitoring activities including, but not limited to scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by VA and FedRAMP requirements.
18. The Contractor shall provide a Monthly VA License Report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

- A. VA Implementation Diagram
- B. 3PAO Security Assessment Plan (SAP)
- C. 3PAO Security Assessment Report (SAR)
- D. Plan of Action and Milestones Reports
- E. Monthly VA License Report

5.1.2 IF THE SOLUTION IS FedRAMP AUTHORIZED AND VA AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA) and have a current VA authorization.
2. The Contractor shall remain in compliance with [FedRAMP](#) requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The FedRAMP Authorization level and existing VA ATO should be no less than the level required for this use case which has been defined as Moderate impact level.
4. The Contractor shall, where applicable, assist with the VA ATO Sustainment Process to help maintain health and quality of agency authorization of the cloud service or migrated application.
5. The Contractor shall exclusively provide subscription licenses to FedRAMP authorized and VA authorized environments.
6. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall bring the situation to the attention of the other party within one hour in

7. accordance with Addendum B, VA Information and Information System Security/Privacy Language. VA Privacy and Security deliverables as directed by the VA System owner.
8. The Contractor shall comply with FedRAMP data management requirements.
9. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
10. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy Guide found on the FedRAMP Website.
11. The Contractor shall provide continuous monitoring activities including, but not limited to, scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by FedRAMP requirements.
12. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
13. The Contractor shall provide a Monthly VA License report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

- A. Continuous Monitoring Monthly Scans
- B. Plan of Action and Milestones Reports.
- C. Monthly VA License Report

5.2 SPECIFIC TASKS AND DELIVERABLES

5.2.1 CONTRACTOR PROJECT MANAGEMENT PLAN

The Contractor shall deliver a Contractor Project Management Plan (CPMP) that lays out the Contractor's approach, timeline, and tools to be used in execution of this Task Order (TO) effort. The CPMP should take the form of both a narrative and graphic format that displays the schedule, milestones, risks, and resource support. The CPMP shall also include how the Contractor shall coordinate and execute planned, routine, and ad hoc data collection reporting requests as identified within the PWS. The initial baseline CPMP shall be concurred upon and updated in accordance with Section B of the TO. The Contractor shall update and maintain the VA Program Manager (PM) approved CPMP throughout the PoP.

Deliverable:

- A. Contractor Project Management Plan

5.2.2 PRIVACY & HIPAA TRAINING

The Contractor shall submit Talent Management System (TMS) training certificates of completion for VA Privacy and Information Security Awareness and Rules of Behavior Training and Health Insurance Portability and Accountability Act (HIPAA) training and provide signed

copies of the Contractor Rules of Behavior in accordance with Section 9, Training, from Appendix C of the VA Handbook 6500.6, "Contract Security".

Deliverables:

- A. VA Privacy and Information Security Awareness and Rules of Behavior Training Certificate
- B. VA HIPAA certificate of completion

5.2.3 TECHNICAL KICKOFF MEETING

A technical kickoff meeting shall be held within 10 days after TO award. The Contractor shall coordinate the date and time of a virtual meeting with the Contracting Officer (CO), the VA PM, the Contract Specialist, and the Contracting Officer Representative (COR). The Contractor shall provide a draft agenda to the CO and VA PM at least five (5) calendar days prior to the meeting. Upon Government approval of a final agenda, the Contractor shall distribute to all meeting attendees. The Contractor shall prepare and distribute the meeting minutes of the kickoff meeting to the CO, COR, and all attendees within three (3) calendar days after the meeting. The Contractor shall obtain concurrence from the COR on the content of the meeting minutes prior to distribution of the document.

Deliverables:

- A. Kickoff Meeting Agenda
- B. Kickoff Meeting Minutes

5.3 COMMERCIAL-OFF-THE-SHELF (COTS) EDISCOVERY PRODUCT

The eDiscovery platform shall provide the following business capabilities that are required to comply with Federal eDiscovery Law and VA requirements, and to ensure that the OGC and OAWP will be capable of producing ESI in a timely, repeatable, and defensible manner within 30 calendar days of contract award. The required business capabilities include:

1. Provide the capability for an average of 100 concurrent users or the ability to support approximately 1,000 named users, depending on platform user licensing model.
2. Support the opening of 450 new cases per year, average case size 350 gigabyte (GB).
3. Support VA staff ability to upload/download ESI, including an initial upload of approximately 300TB of existing data from VA's current platform.
4. Ability to Read, Import, Process, and Export industry standard Concordance formatted data files.
5. Support a single tenant cloud hosting architecture, with the capability to support the multiple internal VA business organizations and requiring no access to each other's workspace.
6. Accommodate Microsoft Entra ID authentication or other VA approved authentication methods.

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

7. VA Entra ID authentication and authorization must be a native function without additional on-premises devices.
8. Must support role-based access with 2-factor authentication.
9. Role-based access is defined based on type of user (attorney, paralegal, etc) with a standard set of permissions and the ability to granularly customize access with additional security/permission attributes for individual users.
10. Allow for future interoperability with Office 365, SharePoint, OneDrive, and Microsoft (MS) Teams.
11. Compliance with VA Section 508 Office requirements shall be implemented and successfully tested within 90 days of all software update/upgrade releases.
12. 508 Accessibility features are activated/deactivated at the user level.
13. Support utilization of VA security protocols to automate discovery and collection.
14. Perform Authentication, Authorization, and Accounting (AAA) to validate parties attempting to log on to a system or application as authorized users to include tracking access credentials for the protection of federal information assets and to log and prevent unauthorized access to those assets.
15. Provide knowledge management capture services in order to record problem-solving knowledge to include the processes, techniques, and technologies for collecting information so that it may be stored for publishing and reuse.
16. Manage official Government records to enforce policies and rules for the retention and disposition of Government information and records.
17. Conduct data governance to establish and manage policies, processes, and standards for the management of VA data to include the identification and designation of VA common data, appoint data stewards for information subject areas, and identification and designation of Authoritative Data Sources for VA data.
18. Provide business intelligence services to deliver the applications, tools, services, and best practices that enable access to and analysis of information to improve and optimize VA decisions and performance.
19. Perform business analytics using VA data to perform statistical analysis, reporting, and visualizations to provide meaningful information to VA and to external Federal entities as required for regulatory and oversight purposes.
20. The eDiscovery solution shall conform to the Electronic Discovery Reference Model (EDRM) framework guidance as follows:
 - a. **Analysis** - Perform analytical functions in a manner consistent with federal law, matching current industry standards as of 2026 for reliability, user friendliness, and customizability. The solution shall accommodate evaluation of ESI for content and context, including key patterns and topics, to search, triage, predictively code, organize, and report on large volumes of data as follows:

- 1) Audio search.
 - 2) Automated identification of Social Security numbers (SSNs) or other Personally Identifiable Information (PII).
 - 3) Concept clustering.
 - 4) Database reporting, visualizations, and exports.
 - 5) Email threading.
 - 6) Full search capabilities - including Boolean logic, fuzzy or stemmed searching, saved searches, search history, and dynamic or scheduled search updating among many search features.
 - 7) Keyword highlighting.
 - 8) Near-duplicate identification, searching, and clustering.
 - 9) Predictive coding and Technology Assisted Review (TAR), including Simple Passive Learning, Simple Active Learning, Continuous Active Learning, and/or other eDiscovery-focused AI capabilities.
 - 10) TAR analytics are rendered with visualizations features include graphs, word clouds and/or circle clusters.
- b. **Processing** - Reduce the volume of ESI and convert it as needed for review and analysis. The solution capabilities shall consist of:
- 1) Processing (indexing) speed of no less than 500GB per hour.
 - I. 70% of documents shall be indexed on the first attempt.
 - II. 95% of documents shall be indexed on the second attempt.
 - III. 100% of documents shall be indexed on the third attempt
 - 2) Data De-duplication in the way of Duplicate suppression and Near-duplication.
 - 3) Removal of all files on a specific list of file types deemed to be of no evidentiary value; "De-NISTing" utilizing the list created by the National Institute of Standards and Technology (NIST).
 - 4) Moving documents containing certain file paths.
 - 5) Omitting certain multipurpose internet mail extension (MIME) types (e.g., system files and executables).
 - 6) Eliminating files that fall below a size threshold.

- 7) Processing ESI based on date range restrictions.
 - 8) Not extracting certain types of "children" or "embedded objects" as separate records (e.g., inline images in office documents and emails).
 - 9) Clustering the data using semantic analysis.
 - 10) Grouping by date and custodian.
 - 11) Allowing manual custodian assignments.
 - 12) Processing digital audio files.
 - 13) Email threading and reconstructing communication threads.
 - 14) Full text indexing.
 - 15) Providing logs of what was accomplished and what failed during processing, such as:
 - I. No document text.
 - II. Optical Character Recognition (OCR) being extracted from the ESI.
 - III. Encrypted or password-protected files.
 - IV. Errors encountered due to corrupted files.
- c. **Review** - Evaluate ESI for relevance and privilege in a simple, efficient manner, matching industry standards as of 2026 for reliability, maintainability, scalability, and user interface design. Capabilities shall include:
- 1) Accessibility (508 compliance, use with all current VA supported versions of web browsers, dual screen functionality, ability to adjust text/font size, security/permissions options).
 - 2) Document navigation and retrieval in 4 seconds or less from TIC gateway.
 - 3) Audit logging of user actions.
 - 4) Automatic OCR for image and PDF file formats.
 - 5) Batching for review.
 - 6) Document redaction.
 - 7) Document printing and downloads or exports by end users.
 - 8) Document tagging and bulk tagging.
 - 9) Family group tagging/review flexibility.

- 10) Keyword highlighting including folder or review batch-based persistent highlighting.
 - 11) Proprietary document viewer capabilities, true native document view options or integration.
 - 12) Scalability for VA use.
 - 13) Visibility of metadata, hidden data, and Microsoft in-document tracked changes or comments.
 - 14) Ability to show/hide different folders for different user profiles within a case
 - 15) Ability to show/hide different tagging attributes within a case for different user roles/profiles and for individual users.
- d. **Production** - Deliver ESI to intended recipients in appropriate forms and using appropriate delivery mechanisms as follows:
- 1) Produce in Load File format and create Load File Exports Templates.
 - 2) Export or “package” case data in a format that can be more readily and directly loaded into a downstream application for review and analysis.
 - 3) Produce “metadata” exports.
 - 4) Capability to export with Nested Attachments.
 - 5) Execute image-based productions.
 - 6) Support custom headers and footers.
 - 7) Support watermark labeling of documents.
 - 8) Support Bates stamp or other unique file identifiers for native files.
 - 9) Enable a reviewer to undo highlighting or other native attorney work product appearing on documents.
 - 10) Hash (encrypt) ESI production artifacts.
- e. **Presentation** - Display ESI data findings before audiences at depositions, hearings, trials, etc., especially in native and near-native forms, to elicit further information, validate existing facts or positions, or persuade an audience.
21. **Preservation** - Ensure that potentially e-discovery-relevant ESI is properly stored and protected against inappropriate alteration or destruction using measures such as retention and deletion schedules.

22. Advanced Artificial Intelligence (AI) – Due to the rapidly developing nature of the technology, the following are preferred features. The VA requires an integrated eDiscovery platform that implements and leverages advanced AI technologies - including, but not limited to, industry-standard Generative AI and Agentic AI capabilities. The following are objectives and features the VA is envisioning to increase the efficiency, accuracy, and defensibility of the document review process.

a. Natural Language Query Interface

- The platform should provide a search interface that allows users to execute queries using plain-English instructions, leveraging natural language processing (NLP) to interpret intent, context, and semantic meaning.

b. Content Summarization Feature

- The platform should provide the ability to generate natural language summaries of documents, folders, and search results.

c. Generative and Agentic AI-based Predictive Coding Tool

- The platform should provide features that automate reviews through predictive coding based on natural language prompts that can be leveraged for reviews for both relevancy and privilege without manual training sets.

d. Automated PII/PHI Identification and Redaction Tool

- The platform should provide the ability to automatically identify, recommend, and apply redactions for Personally Identifiable Information (PII) and Protected Health Information (PHI).

e. Concept Searching and Clustering Feature

- The platform should provide a solution that allows users to visualize the data landscape, identifying and grouping conceptually similar documents.

f. Permission-based user access/features

- The platform should allow user-based permissions to be applied for access and use of AI features/tools that can be controlled by administrators.

g. Human-in-the Loop Design

- The AI tools should be designed as assistive technology, allowing for user verification and correction. The platform should provide metrics to validate the accuracy of AI suggestions based on recall and precision.

h. Ability to control and audit data generated from AI features and its usage.

- The platform must generate comprehensive audit trails tracking which user activated an AI feature, the parameters used, and output generated. It should also provide access and control to any data generated or created to be used by the various AI features, including the ability to control any potential hosting impacts from its usage.

i. Transparency

- Upon request, on an as-needed basis, the Vendor shall provide documentation regarding the risk management processes used to ensure AI outputs are non-discriminatory and reasonably accurate.

j. AI Data Usage and Prompt Security

- The platform must prevent exposure or unauthorized access to AI prompt queries used by the Agency, storing them in encrypted, secure logs. User-uploaded data, confidential information, or case-specific data will not be used to train, update, or refine Vendor's underlying AI models.

5.4 EDISCOVERY IMPLEMENTATION

5.4.1 REQUIREMENTS

During the implementation, the Contractor shall complete requirements sessions with the VA business customer, users, and OI&T staff (hereinafter "VA Team") to properly understand and refine business requirements for implementation. The outcome shall be a detailed understanding of VA business customer needs which shall be documented in Requirements Session Meeting Notes.

Deliverables:

- A. Requirements Sessions Meeting Notes

5.4.2 DESIGN

The Contractor shall ensure that the product design includes software configurations, interface specifications, screen and report designs, and security control specifications. The design document shall reflect the physical, functional, and operational architecture of the Contractor's solution including constraints to functionality and any gaps. The system/software information shall be captured in the System/Software Design Document (SDD). The SDD shall at a minimum address the following:

1. Establish the system architecture to include key interfaces between the cloud application and VA systems.
2. Include design considerations for security and audit procedures, archival of historical data, data migration and data handling criteria, scheduling, disaster recovery, and quality assurance factors.
3. Identify, define, and design capacity and performance requirements and any associated limitations. Specifically, coordinate with the Government to identify limitations and considerations during the design phase.
4. Apply VA standards complying with security requirements, enterprise architecture, data standardization, format, transmission, and storage in adherence with VA standards identified in the One-VA Technical Reference Model (TRM).

Deliverables:

- A. System Design Document (SDD)

5.4.3 CONFIGURATION & IMPLEMENTATION

The Contractor shall provide eDiscovery application configuration services that are consistent with its standard implementation and deployment methodology. The Contractor shall configure the application to meet all VA's requirements as stipulated in this PWS. The Contractor shall provide guidance on alternative approaches to minimize future customizations of the application. The Contractor shall perform all configuration of the systems prior to deployment. The Contractor shall prepare a Change and Configuration Management Plan in accordance with all applicable regulatory policy and guidance. The Change and Configuration Management Plan shall contain all information relevant to defining and modifying the application from the initial baseline configuration and subsequent re-baselining activities.

The Contractor shall assist the VA project teams with data migration as outlined in section 5.8 from existing eDiscovery software to be completed within 60 days of receipt of Authority to Operate (ATO).

Deliverables:

- A. Change and Configuration Management Plan

5.4.4 PROVIDE NETWORK CONNECTIVITY

The Contractor's hosted cloud environment shall have established and approved direct access to the VA Trusted Internet Connection (TIC) 2.0 Gateway Connection. Connectivity between the Cloud Service Provider (CSP) and the VA TIC shall comply with TIC Reference Architecture Document Version 2.0. The Contractor shall not send or receive data to the VA network without an approved ATO from VA. Any deployment outside of the VA firewall is subject to VA TIC 2.0 Gateway Connection requirements for communication with other VA systems within the VA Firewall.

The Contractor shall provide network solutions for connectivity between the primary and secondary site, subject to Federal Information Processing Standard (FIPS)-140-2 certification and (FIPS)-140-3 when required of equipment and configurations and the criteria set forth by the System Security Plan (SSP).

The Contractor shall deliver the following network functionality:

1. Provide network connectivity that complies with FIPS 140-2, Section 1, Table 1, up to and including Security Level 3.
2. The Contractor solution shall support Internet Protocol Version 6 (IPv6) in accordance with the directive issued by the Office of Management and Budget (OMB) on September 28, 2010, IPv6 technology, in accordance with the USGv6: "Technical Infrastructure for IPv6 Adoption" and the NIST SP 800 series applicable compliance shall be included in

all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices shall support dual stack connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g., web, email, DNS, ISP services, etc.) shall support native IPv6 users, and all internal infrastructure and applications shall communicate using native IPv6 operations.

3. All user connectivity to the cloud hosting environment shall be through the TIC gateway. Users shall not be capable of accessing the Case Management System or background investigation data through an internet connection direct to the cloud that bypasses the TIC gateway.
4. The Contractor shall provide a Service Level Agreement (SLA) document identifying the expected availability of the application. Availability of 99.9 percent is required, with a maximum amount of unplanned downtime per year not to exceed 8 hours.

Deliverable:

- A. Service Level Agreement

5.4.5 TEST & EVALUATION (T & E)

The Contractor shall support the testing by the VA (e.g., unit, functional, accessibility, system, reliability, usability, interoperability, regression, security, performance) throughout the implementation cycle using industry best practices. The Contractor shall correct or mitigate any deficiencies discovered during such testing, at no additional cost.

5.4.6 MONTHLY REPORTING

The Contractor shall provide a Monthly Status Report for the eDiscovery system. The Monthly Status Report shall include at a minimum the following data and information:

- A. Monthly Project Cost Platform Utilization: Provide information showing VA how much it cost for the services provided for the month and Year-to-date.
- B. Successful processing/indexing percentage – Provide information on the success rate of indexing documents on the first, second, and third attempts.
- C. Analysis and Review Performance – Provide information on the success of retrieving documents in 4 seconds or less and 100% Native document rendering.
- D. Output/Production - Shall include number of successful operations.
- E. Monthly Up-time - 99.9% Application availability over the course of the previous 30 days and year-to-date.
- F. Security Compliance - Application compliance with VA Security standards.
- G. Web Request/Database Metrics - The number of transactions over the period of observation.

Deliverable:

- A. Monthly Status Reports

5.5 EDISCOVERY TRAINING

Training shall be available throughout the duration of the task order to include each Option Period. Training shall be role-based (user, admin, etc.). The Contractor shall provide training as follows:

1. Provide four (4) Web training sessions to train approximately 300 VA staff during transition
2. Provide Train-the-Trainer support.
3. Provide pre-recorded training for on-going VA staff training.
4. Provide training for new and updated software modules as released.
5. Online Help Center with step by step guides and release notes.
6. Live and on-demand training sessions and webinars.
7. Scheduled bi-weekly (every other week) Office hours.
8. Scheduled bi-weekly (every other week) Q&A sessions.
9. Customized customer playbooks and user manuals.

The Contractor shall deliver or provide links to training plans, manuals and other training documentation or training aids. Electronic training tools such as video teleconferencing and computer-based training shall be employed to enhance the effectiveness of training materials and courses. The Contractor shall identify and/or provide any additional training required by end-users, technicians, or any other staff for implementation, maintenance and use of deliverables specified in individual Task Orders.

Deliverable:

- A. Training plans, manuals and other training documentation and training aids.
- B. Training, and Office Hours and Q&A sessions.

5.6 EDISCOVERY SUPPORT

The Contractor shall provide operations support and systems maintenance support of the application for the life of the task order to include each Option Period as follows:

1. The Contractor shall ensure the application is maintained to the most recent approved COTS baseline.
2. The Contractor shall perform software maintenance activities that may include version and release upgrades, security updates or patches, performance enhancements, data cleansing/archiving, and application modifications. The Contractor shall provide notifications or access to release documentation.
3. The Contractor shall provide proactive operation health monitoring of the application. The Contractor shall provide either notification or access to information about the application availability.
4. The Contractor shall provide a 24/7 toll-free monitored Help Desk number to provide application support services for users of the application. Any telephone support provided by the Contractor shall be at no additional cost. Unresolved support issues will be elevated to the VA Enterprise Service Desk for submission of a service ticket. The

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

Contractor shall provide input and technical support to VA help/service desks on all layers until resolution.

5. Have a designated Customer Service Manager (CSM) to perform the following duties:
 - a. Serve as the primary point of contact for program oversight and coordination
 - b. Ensure platform adoption and alignment with KPIs
 - c. Facilitate executive visibility and roadmap discussions
 - d. Conduct regular business reviews.
 - e. Weekly status meetings.
 - f. Performance check-ins every other week.
 - g. Track operational metrics such as turnaround times, action items, cost control, and usage trends
 - h. Manage customer enhancement requests and ensure alignment with future product development
 - i. Rapid escalation processes to engineering and infrastructure teams
 - j. Produce Root Cause Analysis (RCA) if needed

Deliverables:

- A. Toll-Free Help Desk Phone Number
- B. Notifications or access to release documentation.
- C. Notification or access to information about the application availability.
- D. CSM meetings as noted above in Section 5.6.5

5.7 ASSESSMENT, AUTHORIZATION, AND CONTINUOUS MONITORING

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA).
2. The Contractor shall comply with FedRAMP requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The Contractor shall, assist with the VA ATO Process to achieve agency authorization of the cloud service or migrated application by providing all required documentation in order to attain a VA ATO.
4. The Contractor shall provide an Incident Response Plan (IRP) scenario within 14 days of award and complete Table-Top exercise within 21 days of award unless current VA IRP can be provided.
5. The Contractor shall provide a System Boundary Diagram that demonstrates implementation and any proposed VA interconnections including required ports and protocols at the time award.

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

6. The Contractor shall complete a FedRAMP System Security Plan (SSP) and supporting documentation at the time of award.
7. The Contractor shall complete a Third-Party Assessment Organization (3PAO) Security Assessment Plan (SAP) at the time of award.
8. The Contractor shall complete a 3PAO Security Assessment Report (SAR) at the time of award.
9. To the extent required to carry out the FedRAMP assessment and authorization process and FedRAMP continuous monitoring, to safeguard against threats and hazards to the security, integrity, and confidentiality of any non-public VA data collected and stored by the Contractor, the Contractor shall provide the VA access to the Contractor's and Cloud Service Provider's facilities, installations, technical capabilities, operations, documentation, records, and databases.
10. If new or unanticipated threats or hazards are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall immediately bring the situation to the attention of the other party in accordance with the security addendum B.
11. The Contractor shall not release any data without the written consent of VA. All requests for release must be submitted in writing to the COR/CO.
12. In order for live VA data to be used in this system, a FedRAMP Authorization and VA ATO will be required.
13. Identified gaps between required FedRAMP Security Control Baselines and Continuous Monitoring controls and the contractor's implementation as documented in the Security Assessment Report shall be tracked by the Contractor for mitigation in a Plan of Action and Milestones (POA&M) document. Depending on the severity of the gaps, VA may require them to be remediated before a provisional or agency authorization is issued.
14. The Contractor shall maintain a security management continuous monitoring environment based upon the latest edition of the VA Cloud Computing Continuous Monitoring Process, FedRAMP Security Controls Baseline and FedRAMP Continuous Monitoring Strategy Plan.
15. The Contractor shall comply with all VA and FedRAMP privacy requirements.
16. VA may choose to cancel the Contract and terminate any outstanding orders if the contractor has its ATO revoked and the deficiencies are greater than VA risk tolerance thresholds.

Contractor shall be paid as follows:

- 30 days after award: Completed FedRAMP System Security Plan (SSP) and supporting documentation (**10% of contract value billable after review and acceptance**)
- 30 days after award: 3PAO Security Assessment **Plan** (SAP) (**10% of contract value billable after review and acceptance**)
- 30 days after award: 3PAO Security Assessment **Report** (SAR) (**10% of contract value billable after review and acceptance**)

The remaining 70% will be billable when all ATO work is complete.

Deliverables:

- A. System Boundary Diagram
- B. FedRAMP System Security Plan (SSP) and supporting documentation
- C. 3PAO Security Assessment Plan (SAP)
- D. 3PAO Security Assessment Report (SAR)

5.8 MIGRATION TASKS

This requirement is not intended to limit competition. The VA remains fully open to considering an alternative “brand name or equal” solution, provided it meets the requirements of the PWS/PD. The awardee must complete the migration to the newly proposed solution within 90 days of contract award. The transition must be executed without degradation to VA’s network infrastructure.

If migration is required, the Contractor shall deliver a Contractor Project Management Plan (CPMP) that lays out the Contractor’s approach, timeline, and tools to be used in execution of the contract. The CPMP should take the form of both a narrative and graphic format that displays the schedule, milestones, risks, and resource support. The CPMP shall also include how the Contractor shall coordinate and execute the migration. The Contractor shall update and maintain the VA PM approved CPMP throughout the PoP.

The contractor shall be responsible for planning, executing, and validating the end-to-end data migration from legacy systems to the target platform, ensuring data integrity, security, and minimal business disruption throughout the process. This includes developing a detailed migration strategy and schedule; performing data profiling, cleansing, and transformation; and defining, testing, and implementing migration scripts or tools in alignment with the organization’s data governance and security policies. The contractor must verify completeness and accuracy of migrated data through reconciliation and user acceptance testing, provide clear documentation of mappings and procedures, and coordinate closely with stakeholders to address defects or discrepancies identified during testing. Additionally, the contractor shall provide knowledge transfer and support during cutover and post-migration stabilization to ensure continuity of operations and effective use of the migrated data.

5.9 OPTIONAL TASKS

5.9.1 OUTGOING TRANSITION SUPPORT (OPTIONAL TASK 1)

If outgoing migration is required, the Contractor shall deliver a Contractor Project Management Plan (CPMP) that lays out the Contractor’s approach, timeline, and tools to be used in execution of the contract. The CPMP should take the form of both a narrative and graphic

format that displays the schedule, milestones, risks, and resource support. The CPMP shall also include how the Contractor shall coordinate and execute the migration. The Contractor shall update and maintain the VA PM approved CPMP throughout the PoP.

The contractor shall be responsible for planning, executing, and validating the end-to-end data migration from legacy systems to the target platform, ensuring data integrity, security, and minimal business disruption throughout the process. This includes developing a detailed migration strategy and schedule; performing data profiling, cleansing, and transformation; and defining, testing, and implementing migration scripts or tools in alignment with the organization's data governance and security policies. The data must be converted into a format that target system can ingest. The contractor must verify completeness and accuracy of migrated data through reconciliation and user acceptance testing, provide clear documentation of mappings and procedures, and coordinate closely with stakeholders to address defects or discrepancies identified during testing. Additionally, the contractor shall provide knowledge transfer and support during cutover and post-migration stabilization to ensure continuity of operations and effective use of the migrated data.

If the Optional Task is exercised by VA, the Contractor shall provide a Transition Plan for 90 days of outgoing transition support for transitioning work from the existing Task Order (TO) to another Contractor or Government entity. In accordance with the Government-approved plan, the Contractor shall execute the plan to complete the transition of the existing TO from the incumbent to a successor. This shall include formal coordination with Government staff and successor staff and management. It shall also include transfer of all appropriate records to the COR and PM. This Transition Plan shall include at a minimum:

1. Coordination with Government representatives.
2. Review, evaluate, and transition the current support services.
3. Transition of historic data to new Contractor system via conversion of all case data in the system to the industry standard Concordance format.
4. Transition of system accounts.
5. Transfer of all necessary business and/or technical documentation.
6. Turn-in of all Government keys, ID/access cards, and security codes.

The Contractor shall provide a written Closeout Report that summarizes the delivery of services for the previous quarter. The Contractor shall identify issues and current status of any pending projects.

Deliverables:

- A. Transition Plan
- B. Closeout Report
- C. All data in an industry standard format.

5.9.2 ADDITIONAL STORAGE (OPTIONAL TASK 2)

If the Optional Task is exercised by VA, the Contractor shall provide an additional 20TB of data storage. This optional task may be exercised multiple times, and at any time during the base and/or option periods (if exercised) up to 20 times for up to a total of 400TB.

5.9.3 ADDITIONAL CONCURRENT USERS (OPTIONAL TASK 3)

If the Optional Task is exercised by VA, the Contractor shall provide an additional 10 Concurrent Users. This optional task may be exercised multiple times, and at any time during the base and/or option periods (if exercised) up to 18 times for up to a total of 180 Additional Concurrent Users.

6.0 GENERAL REQUIREMENTS

6.1 ENTERPRISE AND IT FRAMEWORK

6.1.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

6.1.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) will not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation will result in VA discontinuing the use of the system.

6.1.3 FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

The Contractor shall ensure Commercial Off-The-Shelf (COTS) product(s), software configuration and customization, and/or new software are Personal Identity Verification (PIV) card-enabled by accepting HSPD-12 PIV credentials using [VA Enterprise Architecture \(EA\)](#), and VA Identity and Access Management (IAM) approved [Enterprise Technology Guidelines \(ETG\)](#). The Contractor shall ensure all Contractor delivered applications and systems comply with the VA Identity, Credential, and Access Management policies and guidelines set forth in Executive Order 14028, VA Handbook 6510 VA Identity and Access Management, VA Handbook 0735 Homeland Security Presidential Directive 12 (HSPD-12) Program, CISA Binding Operational Directive 23-01, and align with the Federal Identity, Credential, and Access Management Roadmap and Implementation Guidance v2.0.

The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-63-3, VA Handbook 6500, and VA IAM enterprise requirements for direct, assertion based authentication, and/or trust based authentication, as determined by the ETGs. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV card and/or Common Access Card (CAC), as determined by the business need.

The Contractor shall ensure all Contractor delivered applications and systems conform to the specific Identity and Access Management PIV requirements set forth in the Office of Management and Budget (OMB) Memoranda [M-05-24](#), [M-19-17](#), [M-22-09](#), and NIST Federal Information Processing Standard (FIPS) 201-3. Contractor delivered applications and systems shall be on the FIPS 201 Approved Product List (APL). If the Contractor delivered application and system is not on the APL, the Contractor shall be responsible for taking the application and system through the FIPS 201 Evaluation Program.

The Contractor shall ensure all Contractor delivered applications and systems support:

1. Automated provisioning and are able to use enterprise provisioning service.
2. Interfacing with VA's Master Person Index (MPI) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
3. The VA defined unique identity (Secure Identifier [SEC ID] / Integrated Control Number [ICN]).
4. Multiple authenticators for a given identity and authenticators at every Authenticator Assurance Level (AAL) appropriate for the solution.
5. Identity proofing for each Identity Assurance Level (IAL) appropriate for the solution.
6. Federation for each Federation Assurance Level (FAL) appropriate for the solution, if applicable.
7. Two-factor authentication (2FA) through an applicable Technology Guideline as outlined in VA ETG.
8. A Security Assertion Markup Language (SAML) implementation if the solution relies on assertion-based authentication. Additional assertion implementations, besides the required SAML assertion, may be provided as long as they are compliant with NIST SP 800-63-3 guidelines.

9. Authentication/account binding based on trusted Hypertext Transfer Protocol (HTTP) headers if the solution relies on Trust based authentication.
10. Role Based Access Control.
11. Auditing and reporting capabilities.
12. Compliance with VIEWS 00155984, PIV Logical Access Policy Clarification
<https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>.

The required Assurance Levels for this specific effort are Identity Assurance Level 3, Authenticator Assurance Level 3, and Federation Assurance Level 3.

6.1.4 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contractor solution shall support IPv6-Only based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>). Which defines IPv6-only as the state of an operational system or service when IPv4 protocol functions (addressing, packet forwarding) are not in use. The NIST USGv6 profile defines technical requirements for a product to be capable of operating in IPv6-Only environments. IPv6-Only technology, in accordance with the USGv6 Program (<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>), NIST Special Publication (SP) 500-267B Revision 1 “USGv6 Profile” (<https://doi.org/10.6028/NIST.SP.500-267Br1>), and NIST SP 800-119 “Guidelines for the Secure Deployment of IPv6” (<https://doi.org/10.6028/NIST.SP.800-119>), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices, applications, and systems shall support all applicable functionality on native IPv6-Only as well as dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g., web, email, DNS, ISP services, etc.) shall support native IPv6-Only and dual stack (IPv6 / IPv4) users and all internal infrastructure and applications shall support using native IPv6-Only and dual stack (IPv6 / IPv4) for all functionality and operations.

6.1.5 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, “Update to the Trusted Internet Connections (TIC) Initiative” (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 “Secure External Connections”, and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (<https://www.cisa.gov/publication/tic-30-core-guidance-documents>).

6.1.6 STANDARD COMPUTER CONFIGURATION

The Contractor IT end user solution that is developed for use on standard VA computers shall be compatible with and be supported on the standard VA operating system, Windows 10 (64bit) and Windows 11, Edge (Chromium based), and 365 Apps for enterprise. Applications delivered to VA and intended to be deployed to Windows 10 and or Windows 11 workstations shall be delivered as a signed .msi package with switches for silent and unattended installation and updates shall be delivered in signed .msp file formats for easy deployment using Microsoft Endpoint Configuration Manager (CM) VA's current desktop application deployment tool. Signing of the software code shall be through a vendor provided certificate that is trusted by VA using a code signing authority such as Verizon/Cybertrust or Symantec/VeriSign. The Contractor shall also ensure and certify that their solution functions as expected when used from a standard VA computer, with non-admin, standard user rights that have been configured using the Defense Information Systems Agency (DISA) Secure Technical Implementation Guide (STIG) specific to the particular client operating system being used.

6.1.7 VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)

The Contractor shall support VA efforts IAW the Veteran-Focused Integration Process (VIP) Guide and Product Line Management (PLM) Playbook. The major focus of VIP is on Enterprise Oversight, Governance, reporting, and establishing practices that focus on outcomes and continuously delivering sustainable IT capabilities to benefit the Veteran. PLM is a framework that focuses on delivering functional products that provide the highest priority work to customers while delivering simplified, reliable, and practical solutions to the business, medical staff, and our Veterans. The VIP Guide is a companion guide to the PLM Transformation Playbook and can be found at: <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371> and the PLM Transformation Playbook can be found at <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>. VIP and PLM are the authoritative processes that IT projects must follow to ensure development and delivery of IT products.

The VIP Guide provides guidance for transitioning from project-centric to product-centric delivery. The VIP guide applies to all OIT Office of Management and Budget (OMB) reportable products that are required to collect and report costs, schedules, risks, and other valuable information in VA PARS (whether products are procured or developed by VA) and any VA Information Technology project effort in Software Product Management (SPM) and Infrastructure Operations (IO), or their successors, that touch the VA network regardless of IT organizational alignment (whether it spends government funding from VA's Congressional IT Appropriation or any other appropriation).

The PLM Transformation Playbook details how OIT leadership expects Product Lines (PLs) to implement PLM, DevOps, and Lean-Agile principles, methods, practices, and techniques through levels of maturity. The PLM Transformation Playbook applies to all Information Technology (IT) products aligned to PLs in the Software Product Management, Infrastructure Operations and Product Engineering organizations within the OIT organization.

Others outside the referenced groups or organizations may use the VIP Guide and PLM Transformation Playbook for situational awareness as needed.

6.1.8 PROCESS ASSET LIBRARY (PAL)

The Contractor shall perform their duties consistent with the processes defined in the OIT Process Asset Library (PAL). The PAL includes a spectrum of OIT functions and activities, such as project management, operations, service delivery, communications, acquisition, and resource management. PAL serves as an authoritative and informative repository of searchable processes, activities or tasks, roles, artifacts, tools and applicable standards and guides to assist the OIT workforce, Government and Contractor personnel. OIT utilizes PAL processes to ensure compliance with policies and regulations and to meet VA quality standards. The PAL includes the contractor onboarding process consistent with Section 6.2.2 and can be found at [process CONB_ext.docx \(live.com\)](#). The main PAL can be accessed at www.va.gov/process.

6.1.9 AUTHORITATIVE DATA SOURCES

The VA Enterprise Architecture Repository (VEAR) is one component within the overall EA that establishes the common framework for data taxonomy for describing the data architecture used to develop, operate, and maintain enterprise applications. The Contractor shall comply with the department's Authoritative Data Source (ADS) requirement that VA systems, services, and processes throughout the enterprise shall access VA data solely through official VA ADSs where applicable, see below. The Information Classes which compose each ADS are located in the VEAR, in the Data & Information domain. The Contractor shall ensure that all delivered applications and system solutions support:

1. Interfacing with VA's Master Person Index (MPI) (formerly the Master Veteran Index (MVI)) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
2. Interfacing with Capital Asset Inventory (CAI) to conduct real property record management actions, if the solution relies on real property records data. CAI is the authoritative source for VA real property record management data.
3. Interfacing with electronic Contract Management System (eCMS) for access to contract, contract line item, purchase requisition, offering vendor, and solicitation information above the micro-purchase threshold, if the solution relies on procurement data. ECMS is the authoritative source for VA procurement actions data.
4. Interfacing with HRSmart Human Resources Information System to conduct personnel action processing, on-boarding, benefits management, and compensation management, if the solution relies on personnel data. HRSmart is the authoritative source for VA personnel information data.
5. Interfacing with VA Profile to access personal contact information, if the solution relies on VA Veteran personal contact information data. VA Profile is the authoritative source for VA Veteran Personal Contact Data.
6. Interfacing with VA/Department of Defense (DoD) Identity Repository (VADIR) for determining eligibility for VA benefits under Title 38, if the solution relies on qualifying active duty military service data. VADIR is the authoritative source for qualifying active duty military service in VA.

7. Interfacing with VA Systems Inventory (VASI) to access VA systems information, if the solution relies on VA system information. VASI is the authoritative source for VA Information Technology systems.
8. Interfacing with ServiceNow Continuous Authorization and Monitoring (SNOW CAM) to access the Authority to Operate (ATO) status of all VA Information Systems. SNOW CAM contains the official Authority to Operate (ATO) status of all VA Information Systems.

6.1.10 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the ICN in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA MPI for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

6.2 SECURITY AND PRIVACY REQUIREMENTS

It has been determined that protected health information may be disclosed or accessed and a signed Business Associate Agreement (BAA) shall be required. The Contractor shall adhere to the requirements set forth within the BAA, referenced in Section D of the contract, and shall comply with VA Directive 6066.

6.2.1 POSITION/TASK RISK DESIGNATION LEVEL(S)

(The Requiring Activity/Program Manager is required to identify the appropriate position risk designation, which will drive the level of background investigation level (Tier 1/Low Risk, Tier 2/Moderate Risk, Tier 4/High Risk) by PWS task in accordance with VA Handbook 0710. Using the results of the Position Designation Automated Tool (PDT) (also known as PDAT) performed for each Task, complete the table below. This "Task" Position Risk Designation correlates to individual Contractor personnel background investigation levels depending upon which particular tasks the contractor individual is working.

The PDT Tool is located at the following US Office of Personnel Management Website: [Position Designation Tool \(opm.gov\)](https://www.opm.gov/pdt/)

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

In accordance with VA Handbook 0710, Personnel Security and Suitability Program, the position sensitivity and the level of background investigation commensurate with the required level of access for the following tasks within the PWS are:

Position Sensitivity and Background Investigation Requirements by Task

Task Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
5.1	☐	☐	☐
<5.2>	☐	☐	☐
	☐	☐	☐
	☐	☐	☐
	☐	☐	☐
	☐	☐	☐

The Tasks identified above and the resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual will be working. The submitted Contractor Staff Roster must indicate the required Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual will be working, in accordance with their submitted proposal.

6.2.2 CONTRACTOR PERSONNEL SECURITY REQUIREMENTS

Contractor Responsibilities:

- a. The Contractor shall prescreen all personnel requiring access to the computer systems to ensure they maintain the appropriate Background Investigation, and are able to read, write, speak, and understand the English language.
- b. Within 3 business days after award, the Contractor shall provide a roster of Contractor and Subcontractor employees to the COR to begin their background investigations in accordance with the PAL template artifact. The Contractor Staff Roster shall contain the Contractor's Full Name, Date of Birth, Place of Birth, individual background investigation level requirement (based upon Section 6.2 Tasks), etc. The Contractor shall submit full Social Security Numbers either within the Contractor Staff Roster or under separate cover to the COR. The Contractor Staff Roster shall be updated and provided to VA within 1 day of any changes in employee status, training certification completion status, Background Investigation level status, additions/removal of employees, etc. throughout the Period of Performance. The Contractor Staff Roster shall remain a historical document indicating all past information and the Contractor shall indicate in the Comment field, employees no longer supporting this contract. The preferred method to send the Contractor Staff Roster or Social Security Number is by encrypted e-mail. If unable to send encrypted e-mail, other methods which comply with FIPS 140-2 (or its successor) are to encrypt the file, use a secure fax, or use a traceable mail service. (Note that by September 22, 2026, all FIPS 140-2 certificate validations will be

placed on the Historical List. See FIPS Transition Effort Timeline for more details:
<https://csrc.nist.gov/projects/fips-140-3-transition-effort#schedule>)

- c. The Contractor should coordinate with the location of the nearest VA fingerprinting office through the COR. Only electronic fingerprints are authorized. The Contractor shall bring their completed Security and Investigations Center (SIC) Fingerprint request form with them (see paragraph d.4. below) when getting fingerprints taken.
- d. The Contractor shall ensure the following required forms are submitted to the COR within 5 days after contract award:
 - 1) Optional Form 306
 - 2) Self-Certification of Continuous Service
 - 3) VA Form 0710
 - 4) Completed SIC Fingerprint Request Form
- e. The Contractor personnel shall submit all required information related to their background investigations (completion of the investigation documents (SF85, SF85P, or SF 86) utilizing the Office of Personnel Management's (OPM) Electronic Questionnaire for Investigations Processing (e-QIP) after receiving an email notification from the SIC.
- f. The Contractor employee shall certify and release the e-QIP document, print, and sign the signature pages, and send them encrypted to the COR for electronic submission to the SIC. These documents shall be submitted to the COR within 3 business days of receipt of the e-QIP notification email. (Note: OPM is moving towards a "click to sign" process. If click to sign is used, the Contractor employee should notify the COR within 3 business days that documents were signed via e-QIP).
- g. The Contractor shall be responsible for the actions of all personnel provided to work for VA under this contract. In the event that damages arise from work performed by Contractor provided personnel, under the auspices of this contract, the Contractor shall be responsible for all resources necessary to remedy the incident.
- h. A Contractor may be granted unescorted access to VA facilities and/or access to VA Information Technology resources (network and/or protected data) with a favorably adjudicated Special Agreement Check (SAC), completed training delineated in VA Handbook 6500.6 (Appendix C, Section 4), signed "Contractor Rules of Behavior", and with a valid, operational Personal Identity Verification (PIV) credential for PIV-only logical access to VA's network. A PIV card credential can be issued once your SAC has been favorably adjudicated and your background investigation has been scheduled by OPM. However, the Contractor will be responsible for the actions of the Contractor personnel they provide to perform work for VA. The investigative history for Contractor personnel working under this contract must be maintained in the database of OPM.
- i. The Contractor, when notified of an unfavorably adjudicated background investigation on a Contractor employee as determined by the Government, shall withdraw the employee from consideration in working under the contract.
- j. Failure to comply with the Contractor personnel security investigative requirements may result in loss of physical and/or logical access to VA facilities and systems by Contractor and Subcontractor employees and/or termination of the contract for default.

- k. PIV Credential Holders must follow all HSPD-12 policies and procedures as well as use and protect their assigned identity credentials in accordance with VA policies and procedures, displaying their badges at all times, and returning the identity credentials upon termination of their relationship with VA.

Deliverable:

- A. Contractor Staff Roster

6.3 METHOD AND DISTRIBUTION OF DELIVERABLES

The Contractor shall deliver documentation in electronic format, unless otherwise directed in Section B of the solicitation/contract. Acceptable electronic media include: Microsoft 365 suite, MS Word, MS Excel, MS PowerPoint, MS Project, MS Access, MS Visio, AutoCAD, and Adobe Postscript Data Format (PDF).

6.4 PERFORMANCE METRICS

The table below defines the Performance Standards and Acceptable Levels of Performance associated with this effort.

**eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700**

Performance Objective	Performance Standard	Acceptable Levels of Performance
A. Technical / Quality of Product or Service	1. Demonstrates understanding of requirements 2. Efficient and effective in meeting requirements 3. Meets technical needs and mission requirements 4. Provides quality services/products 5. Incorporates "ease of use" Human Centered Design principles in any software developed.	Satisfactory or higher
B. Project Milestones and Schedule	1. Established milestones and project dates are met 2. Products completed, reviewed, delivered in accordance with the established schedule 3. Notifies customer in advance of potential problems	Satisfactory or higher
C. Cost & Staffing	1. Currency of expertise and staffing levels appropriate to perform tasks required 2. Personnel possess necessary knowledge, skills, and abilities to perform tasks	Satisfactory or higher
D. Management	1. Integration and coordination of all activities to execute effort	Satisfactory or higher

The COR will utilize a Quality Assurance Surveillance Plan (QASP) throughout the life of the contract to ensure that the Contractor is performing the services required by this PWS in an acceptable level of performance. The Government reserves the right to alter or change the surveillance methods in the QASP at its own discretion. A Performance Based Service Assessment will be used by the COR in accordance with the QASP to assess Contractor performance.

6.5 FACILITY/RESOURCE PROVISIONS

The Government will provide office space, telephone service and system access when authorized contract staff work at a Government location as required in order to accomplish the

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

Tasks associated with this PWS. All procedural guides, reference materials, and program documentation for the project and other Government applications will also be provided on an as-needed basis.

The Contractor shall request other Government documentation deemed pertinent to the work accomplishment directly from the Government officials with whom the Contractor has contact. The Contractor shall consider the COR as the final source for needed Government documentation when the Contractor fails to secure the documents by other means. The Contractor is expected to use common knowledge and resourcefulness in securing all other reference materials, standard industry publications, and related materials that are pertinent to the work.

VA may provide remote access to VA specific systems/network in accordance with VA Handbook 6500, which requires the use of a VA approved method to connect external equipment/systems to VA's network. Citrix Access Gateway (CAG) and now the Azure Virtual Desktop (AVD) (as VA is currently transitioning from CAG to the AVD), are the current and only VA approved methods for remote access users when using or manipulating VA information for official VA Business. VA permits CAG remote access through approved Personally Owned Equipment (POE) and Other Equipment (OE) provided the equipment meets all applicable 6500 Handbook requirements for POE/OE. All of the security controls required for Government furnished equipment (GFE) must be utilized in approved POE or OE. The Contractor shall provide proof to the COR for review and approval that their POE or OE meets the VA Handbook 6500 requirements and VA Handbook 6500.6 Appendix C, herein incorporated as Addendum B, before use. CAG authorized users shall not be permitted to copy, print, or save any VA information accessed via CAG at any time. VA prohibits remote access to VA's network from non-North Atlantic Treaty Organization (NATO) countries. The exception to this are countries where VA has approved operations established (e.g. Philippines and South Korea). Exceptions are determined by the COR in coordination with the Information System Security Officer (ISSO) and Privacy Officer (PO).

This remote access may provide access to VA specific software such as Veterans Health Information System and Technology Architecture (VistA), ClearQuest, PAL, Primavera, and Remedy, including appropriate seat management and user licenses, depending upon the level of access granted. The Contractor shall utilize government-provided software development and test accounts, documents, and requirements repositories, etc. as required for the development, storage, maintenance, and delivery of products within the scope of this effort. All VA sensitive information shall be protected at all times in accordance with VA Handbook 6500, local security field office System Security Plans (SSP's) and Authority to Operate (ATO)'s for all systems/LAN's accessed while performing the tasks detailed in this PWS. The Contractor shall ensure all work is performed in countries deemed not to pose a significant security risk. For detailed Security and Privacy Requirements (additional requirements of the contract consolidated into an addendum for easy reference) refer to ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED and ADDENDUM B - VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE.

A1.0 VA Enterprise Architecture Compliance

The applications, supplies, and services furnished under this contract must comply with VA Enterprise Architecture (EA), available at <http://www.ea.oit.va.gov/index.asp> in force at the time of issuance of this contract, including the Program Management Plan and VA's rules, standards, and guidelines in the Technical Reference Model/Standards Profile (TRMSP). VA reserves the right to assess contract deliverables for EA compliance prior to acceptance.

A1.1. VA Internet and Intranet Standards

The Contractor shall adhere to and comply with VA Directive 6102 and VA's Web Governance if the Contractor's work includes building and maintaining VA's digital presence. This pertains, but is not limited to: websites, social media, creating announcements; collecting information; databases to be accessed, graphics and links to external sites.

Internet/Intranet Services Directive 6102 is posted at (copy and paste the following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1056&FType=2

VA Web Governance website can be found at [Home - VA Web Governance](#).

A2.0 Notice of the Federal Accessibility Law Affecting All Information and Communication Technology (ICT) Procurements (Section 508)

On January 18, 2017, the Access Board issued a final rule that updated accessibility requirements covered by Section 508 and refreshed guidelines for telecommunications equipment subject to Section 255 of the Communications Act. The final rule went into effect on January 18, 2018. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

A2.1. Section 508 – Information and Communication Technology (ICT) Standards

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: [Revised 508 Standards and 255 Guidelines \(access-board.gov\)](#). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines will be supplied upon request, or can be obtained from the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with "508 Chapter 2: Scoping Requirements" for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria

- ☐ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

A2.2. Compatibility with Assistive Technology

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

A2.3. Acceptance and Acceptance Testing

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of the Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

A3.0 Physical Security & Safety Requirements:

The Contractor and their personnel shall follow all VA policies, standard operating procedures, applicable laws and regulations while on VA property. Violations of VA regulations and policies may result in citation and disciplinary measures for persons violating the law.

1. The Contractor and their personnel shall wear visible identification at all times while they are on the premises.
2. VA does not provide parking spaces at the work site; the Contractor must obtain parking at the work site if needed. It is the responsibility of the Contractor to park in the appropriate designated parking areas. VA will not invalidate or make reimbursement for parking violations of the Contractor under any conditions.
3. Smoking is prohibited inside/outside any building other than the designated smoking areas.
4. Possession of weapons is prohibited.
5. The Contractor shall obtain all necessary licenses and/or permits required to perform the work, with the exception of software licenses that need to be procured from a Contractor or vendor in accordance with the requirements document. The Contractor shall take all reasonable precautions necessary to protect persons and property from injury or damage during the performance of this contract.

A4.0 Confidentiality and Non-Disclosure

The Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations.

The Contractor may have access to Protected Health Information (PHI) and Electronic Protected Health Information (ePHI) that is subject to protection under the regulations issued by the Department of Health and Human Services, as mandated by the Health Insurance Portability and Accountability Act of 1996 (HIPAA); 45 CFR Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 CFR Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"). Pursuant to the Privacy and Security Rules, the Contractor must agree in writing to certain mandatory provisions regarding the use and disclosure of PHI and ePHI.

1. The Contractor will have access to some privileged and confidential materials of VA. These printed and electronic documents are for internal use only, are not to be copied or released without permission, and remain the sole property of VA. Some of these materials are protected by the Privacy Act of 1974 (revised by PL 93-5791) and Title 38. Unauthorized disclosure of Privacy Act or Title 38 covered materials is a criminal offense.
2. The VA CO will be the sole authorized official to release in writing, any data, draft deliverables, final deliverables, or any other written or printed materials pertaining to this contract. The Contractor shall release no information. Any request for information relating to this contract presented to the Contractor shall be submitted to the VA CO for response.
3. Contractor personnel recognize that in the performance of this effort, Contractor personnel may receive or have access to sensitive information, including information provided on a proprietary basis by carriers, equipment manufacturers and other private or public entities. Contractor personnel agree to safeguard such information and use the information exclusively in the performance of this contract. Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations as enumerated in this section and elsewhere in this Contract and its subparts and appendices.
4. Contractor shall limit access to the minimum number of personnel necessary for contract performance for all information considered sensitive or proprietary in nature. If the Contractor is uncertain of the sensitivity of any information obtained during the performance this contract, the Contractor has a responsibility to ask the VA CO.
5. Contractor shall train all of their employees involved in the performance of this contract on their roles and responsibilities for proper handling and nondisclosure of sensitive VA or proprietary information. Contractor personnel shall not engage in any other action, venture or employment wherein sensitive information shall be used for the profit of any party other than those furnishing the information. The sensitive information transferred, generated, transmitted, or stored herein is for VA benefit and ownership alone.
6. Contractor shall maintain physical security at all facilities housing the activities performed under this contract, including any Contractor facilities according to VA-approved guidelines and directives. The Contractor shall ensure that security procedures are defined and enforced to ensure all personnel who are provided access to patient data must comply with published procedures to protect the privacy and confidentiality of such information as required by VA.
7. Contractor must adhere to the following:

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

- a. The use of “thumb drives” or any other medium for transport of information is expressly prohibited.
 - b. Controlled access to system and security software and documentation.
 - c. Recording, monitoring, and control of passwords and privileges.
 - d. All terminated personnel are denied physical and electronic access to all data, program listings, data processing equipment and systems.
 - e. VA, as well as any Contractor (or Subcontractor) systems used to support development, provide the capability to cancel immediately all access privileges and authorizations upon employee termination.
 - f. Contractor PM and VA PM are informed within twenty-four (24) hours of any employee termination.
 - g. Acquisition sensitive information shall be marked "Acquisition Sensitive" and shall be handled as "For Official Use Only (FOUO)".
 - h. Contractor does not require access to classified data.
8. Regulatory standard of conduct governs all personnel directly and indirectly involved in procurements. All personnel engaged in procurement and related activities shall conduct business in a manner above reproach and, except as authorized by statute or regulation, with complete impartiality and with preferential treatment for none. The general rule is to strictly avoid any conflict of interest or even the appearance of a conflict of interest in VA/Contractor relationships.
9. VA Form 0752 shall be completed by all Contractor employees working on this contract and shall be provided to the CO before any work is performed. In the case that Contractor personnel are replaced in the future, their replacements shall complete VA Form 0752 prior to beginning work.

ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE

NOTE: In the event of a conflict, VAAR Security Clauses take precedence over the language in this Addendum B.

APPLICABLE SECTIONS FROM: *VA NOTICE 24-12, APRIL 22, 2024, UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE*

B1. GENERAL

This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, Subcontractors and subcontractor personnel will be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.

B2. VA INFORMATION CUSTODIAL LANGUAGE

- a. The Government shall receive unlimited rights to data/intellectual property first produced and delivered in the performance of this contract or order (hereinafter “contract”) unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General. The primary clause used to define computer software license (not data/intellectual property first produced under this Contractor or order) is FAR 52.227-19, Commercial Computer Software License.
- b. Information made available to the Contractor by VA for the performance or administration of this contract will be used only for the purposes specified in the service agreement, SOW, PWS, PD, and/or contract. The Contractor shall not use VA information in any other manner without prior written approval from a VA Contracting Officer (CO). The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- c. VA information will not be co-mingled with any other data on the Contractor’s information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization.
- d. VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure information security is compliant with Federal and VA requirements. The Contractor shall provide all necessary access to records (including electronic and documentary materials related to the contracts and subcontracts) and support (including access to

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

Contractor and Subcontractor staff associated with the contract) to VA, VA's Office Inspector General (OIG), and/or Government Accountability Office (GAO) staff during periodic control assessments, audits, or investigations.

- e. The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal information security laws, regulations or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and/or policies.
- f. The Contractor shall not make copies of VA information except as specifically authorized and necessary to perform the terms of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program and VA Information Security Knowledge Service.
- g. If a Veterans Health Administration (VHA) contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with VHA Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA will determine what actions are appropriate and notify the contractor.
- h. The Contractor shall store and transmit VA sensitive information in an encrypted form, using VA-approved encryption tools which are, at a minimum, Federal Information Processing Standards (FIPS) 140-2, Security Requirements for Cryptographic Modules (or its successor) validated and in conformance with VA Information Security Knowledge Service requirements. The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with National Institute of Standards and Technology (NIST) 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations.
- i. The Contractor's firewall and web services security controls, as applicable, shall meet or exceed VA's minimum requirements.
- j. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent jurisdiction after notification to VA CO (ii) with written approval from the VA CO. The Contractor shall refer all requests for, demands for production of or inquiries about, VA information and information systems to the VA CO for response.
- k. Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 U.S.C. § 5705, Confidentiality of medical quality-assurance records and/or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt of a court order

or other requests for the above-mentioned information, the Contractor shall immediately refer such court order or other requests to the VA CO for response.

- l. Information made available to the Contractor by VA for the performance or administration of this contract or information developed by the Contractor in performance or administration of the contract will be protected and secured in accordance with VA Directive 6500 and Identity and Access Management (IAM) Security processes specified in the VA Information Security Knowledge Service.
- m. Any data destruction done on behalf of VA by a Contractor shall be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.
- n. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Directive 6500 and NIST 800-88, Guidelines for Media Sanitization prior to termination or completion of this contract. If directed by the COR/CO, the Contractor shall return all Federal Records to VA for disposition.
- o. Any media, such as paper, magnetic tape, magnetic disks, solid state devices or optical discs that is used to store, process, or access VA information that cannot be destroyed shall be returned to VA. The Contractor shall hold the appropriate material until otherwise directed by the Contracting Officer's Representative (COR) or CO. Items shall be returned securely via VA-approved methods. VA sensitive information must be transmitted utilizing VA-approved encryption tools which are validated under FIPS 140-2 (or its successor) and NIST 800-52. If mailed, the Contractor shall send via a trackable method (USPS, UPS, FedEx, etc.) and immediately provide the COR/CO with the tracking information. Self-certification by the Contractor that the data destruction requirements above have been met shall be sent to the COR/CO within 30 business days of termination of the contract.
- p. All electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used to store, process or access VA information will not be returned to the Contractor at the end of lease, loan, or trade-in. Exceptions to this paragraph will only be granted with the written approval of the VA CO.

B3. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

- a. A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees and subcontractors only to the extent necessary to perform the services specified in the solicitation or contract. This includes indirect entities, both affiliate of Contractor/Subcontractor and agent of Contractor/Subcontractor.
- b. Contractors and subcontractors shall sign the VA Information Security Rule of Behavior (ROB) before access is provided to VA information and information systems (see Section 4, Training, below). The ROB contains the minimum user compliance

requirements and does not supersede any policies of VA facilities or other agency components which provide higher levels of protection to VA's information or information systems. Users who require privileged access shall complete the VA elevated privilege access request processes before privileged access is granted.

- c. All Contractors and Subcontractors working with VA information are subject to the same security investigative and clearance requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for contractors shall be in accordance with VA Directive and Handbook 0710, Personnel Suitability and Security Program. The Office of Human Resources and Administration/Operations, Security and Preparedness (HRA/OSP) is responsible for these policies and procedures. Contract personnel who require access to classified information or information systems shall have an appropriate security clearance. Verification of a Security Clearance shall be processed through the Special Security Officer located in HRA/OSP. Contractors shall conform to all requirements stated in the National Industrial Security Program Operating Manual (NISPOM).
- d. All Contractors and subcontractors shall comply with conditions specified in VAAR 852.204-71(d); Contractor operations required to be in United States. All Contractors and Subcontractors working with VA information must be permanently located within a jurisdiction subject to the law of the United States or its Territories to the maximum extent feasible. If services are proposed to be performed abroad the Contractor must state where all non-U.S. services are provided. The Contractor shall deliver to VA a detailed plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the COR/CO in writing prior to access being granted.
- e. The Contractor shall notify the COR/CO in writing immediately (no later than 24 hours) after personnel separation or occurrence of other causes. Causes may include the following:
 - (1) Contractor/Subcontractor personnel no longer has a need for access to VA information or VA information systems.
 - (2) Contractor/Subcontractor personnel are terminated, suspended, or otherwise has their work on a VA project discontinued for any reason.
 - (3) Contractor believes their own personnel or Subcontractor personnel may pose a threat to their company's working environment or to any company-owned property. This includes Contractor-owned assets, buildings, confidential data, customers, employees, networks, systems, trade secrets and/or VA data.
 - (4) Any previously undisclosed changes to Contractor/Subcontractor background history are brought to light, including but not limited to changes to background investigation or employee record.

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

- (5) Contractor/Subcontractor personnel have their authorization to work in the United States revoked.
- (6) Agreement by which Contractor provides products and services to VA has either been fulfilled or terminated, such that VA can cut off electronic and/or physical access for Contractor personnel.
- f. In such cases of contract fulfillment, termination, or other causes; the Contractor shall take the necessary measures to immediately revoke access to VA network, property, information, and information systems (logical and physical) by Contractor/Subcontractor personnel. These measures include (but are not limited to): removing and then securing Personal Identity Verification (PIV) badges and PIV – Interoperable (PIV-I) access badges, VA-issued photo badges, credentials for VA facilities and devices, VA-issued laptops, and authentication tokens. Contractors shall notify the appropriate VA COR/CO immediately to initiate access removal.
- g. Contractors/Subcontractors who no longer require VA accesses will return VA-issued property to VA. This property includes (but is not limited to): documents, electronic equipment, keys, and parking passes. PIV and PIV-I access badges shall be returned to the nearest VA PIV Badge Issuance Office. Once they have had access to VA information, information systems, networks and VA property in their possessions removed, Contractors shall notify the appropriate VA COR/CO.

B4. TRAINING

- a. All contractors and subcontractors requiring access to VA information and VA information systems shall successfully complete the following before being granted access to VA information and its systems:
 - (1) VA Privacy and Information Security Awareness and Rules of Behavior course (Talent Management System (TMS) #10176) initially and annually thereafter.
 - (2) Sign and acknowledge (electronically through TMS #10176) understanding of and responsibilities for compliance with the Organizational Rules of Behavior, relating to access to VA information and information systems initially and annually thereafter; and
 - (3) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system or information access [to be defined by the VA program official and provided to the VA CO for inclusion in the solicitation document – i.e., any role-based information security training].
- b. The Contractor shall provide to the COR/CO a copy of the training certificates and certification of signing the Organizational Rules of Behavior for each applicable employee within five days of the initiation of the contract and annually thereafter, as required.

- c. Failure to complete the mandatory annual training is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the required training is complete.

B5. SECURITY INCIDENT INVESTIGATION

- a. The Contractor, Subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the Contractor, Subcontractor, their employees, or business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.
- b. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).
 - (3) The physical and logical (if applicable) location of the incident.
 - (4) Why the Security Incident took place (i.e., catalyst for the failure).
 - (5) The amount of data belonging to VA believed to have been compromised.
 - (6) The remediation measures the Contractor is taking to ensure no future incidents of a similar nature.
- c. After the Contractor has provided the initial detailed incident summary to VA, they will continue to provide written updates on any new and relevant circumstances or facts they discover. The Contractor, Subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
- d. VA IT Contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.
- e. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.

- f. The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.
- g. With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
- h. If the Contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach involving any VA sensitive personal information the Contractor/Subcontractor processes or maintains under the contract; the Contractor shall pay liquidated damages to the VA as set forth in clause [852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs](#).

B6. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

- a. Information systems designed or developed on behalf of VA at non-VA facilities shall comply with all applicable Federal law, regulations, and VA policies. This includes standards for the protection of electronic Protected Health Information (PHI), outlined in 45 C.F.R. Part 164, Subpart C and information and system security categorization level designations in accordance with FIPS 199, Standards for Security Categorization of Federal Information and Information Systems and FIPS 200, Minimum Security Requirements for Federal Information Systems. Baseline security controls shall be implemented commensurate with the FIPS 199 system security categorization (reference VA Handbook 6500 and VA Trusted Internet Connections (TIC) Architecture).
- b. Contracted new developments require creation, testing, evaluation, and authorization in compliance with VA Assessment and Authorization (A&A) processes in VA Handbook 6500 and VA Information Security Knowledge Service to obtain an Authority to Operate (ATO). VA Directive 6517, Risk Management Framework for Cloud Computing Services, provides the security and privacy requirements for cloud environments.
- c. VA IT Contractors, Subcontractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500, VA Handbook 6517, Risk Management Framework for Cloud Computing Services and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO to identify the VA organization responsible for governance or resolution. Contractors shall comply with FAR 39.1, specifically the prohibitions referenced.

- d. The Contractor (including producers and resellers) shall comply with Office of Management and Budget (OMB) M-22-18 and M-23-16 when using third-party software on VA information systems or otherwise affecting the VA information. This includes new software purchases and software renewals for software developed or modified by major version change after the issuance date of M-22-18 (September 14, 2022). The term "software" includes firmware, operating systems, applications and application services (e.g., cloud-based software), as well as products containing software. The Contractor shall provide a self-attestation that secure software development practices are utilized as outlined by Executive Order (EO) 14028 and NIST Guidance. A third-party assessment provided by either a certified Federal Risk and Authorization Management Program (FedRAMP) Third Party Assessor Organization (3PAO) or one approved by the agency will be acceptable in lieu of a software producer's self-attestation.
- e. The Contractor shall ensure all delivered applications, systems and information systems are compliant with Homeland Security Presidential Directive (HSPD) 12 and VA Identity and Access management (IAM) enterprise identity management requirements as set forth in OMB M-19-17, M-05-24, FIPS 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors (or its successor), M-21-31 and supporting NIST guidance. This applies to Commercial Off-The-Shelf (COTS) product(s) that the Contractor did not develop, all software configurations and all customizations.
- f. The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with VA Handbook 6500, VA Information Security Knowledge Service, IAM enterprise requirements and NIST 800-63, Digital Identity Guidelines, for direct, assertion-based authentication and/or trust-based authentication, as determined by the design and integration patterns. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV and/or Common Access Card (CAC), as determined by the business need and compliance with VA Information Security Knowledge Service specifications.
- g. The Contractor shall use VA authorized technical security baseline configurations and certify to the COR that applications are fully functional and operate correctly as intended on systems in compliance with VA baselines prior to acceptance or connection into an authorized VA computing environment. If the Defense Information Systems Agency (DISA) has created a Security Technical Implementation Guide (STIG) for the technology, the Contractor may configure to comply with that STIG. If VA determines a new or updated VA configuration baseline needs to be created, the Contractor shall provide required technical support to develop the configuration settings. FAR 39.1 requires the population of operating systems and applications includes all listed on the NIST National Checklist Program Checklist Repository,

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

- h. The standard installation, operation, maintenance, updating and patching of software shall not alter the configuration settings from VA approved baseline configuration. Software developed for VA must be compatible with VA enterprise installer services and install to the default "program files" directory with silently install and uninstall. The Contractor shall perform testing of all updates and patching prior to implementation on VA systems.
- i. Applications designed for normal end users will run in the standard user context without elevated system administration privileges.
- j. The Contractor-delivered solutions shall reside on VA approved operating systems. Exceptions to this will only be granted with the written approval of the COR/CO.
- k. The Contractor shall design, develop, and implement security and privacy controls in accordance with the provisions of VA security system development life cycle outlined in NIST 800-37, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, VA Directive and Handbook 6500, and VA Handbook 6517.
- l. The Contractor shall comply with the Privacy Act of 1974 (the Act), FAR 52.224-2 Privacy Act, and VA rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish a VA function.
- m. The Contractor shall ensure the security of all procured or developed information systems, systems, major applications, minor applications, enclaves and platform information technologies, including their subcomponents (hereinafter referred to as "Information Systems") throughout the life of this contract and any extension, warranty, or maintenance periods. This includes security configurations, workarounds, patches, hotfixes, upgrades, replacements and any physical components which may be necessary to remediate all security vulnerabilities published or known to the Contractor anywhere in the information systems (including systems, operating systems, products, hardware, software, applications and firmware). The Contractor shall ensure security fixes do not negatively impact the Information Systems.
- n. When the Contractor is responsible for operations or maintenance of the systems, the Contractor shall apply the security fixes within the timeframe specified by the associated controls on the VA Information Security Knowledge Service. When security fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the Contractor shall provide written notice to the VA COR/CO that the patch has been validated as to not affecting the Systems within 10 business days.

B7. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

- a. The Contractor shall comply with all Federal laws, regulations, and VA policies for Information systems (cloud and non-cloud) that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities. Security controls for collecting, processing,

transmitting, and storing of VA sensitive information, must be in place. The controls will be tested by VA or a VA sanctioned 3PAO and approved by VA prior to hosting, operation, maintenance or use of the information system or systems by or on behalf of VA. This includes conducting compliance risk assessments, security architecture analysis, routine vulnerability scanning, system patching, change management procedures and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures shall be the same as procedures used to secure VA-operated information systems.

- b. Outsourcing (Contractor facility, equipment, or staff) of systems or network operations, telecommunications services or other managed services require Assessment and Authorization (A&A) of the Contractor's systems in accordance with VA Handbook 6500 as specified in VA Information Security Knowledge Service. Major changes to the A&A package may require reviewing and updating all the documentation associated with the change. The Contractor's cloud computing systems shall comply with FedRAMP and VA Directive 6517 requirements.
- c. The Contractor shall return all electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) on non-VA leased or non-VA owned IT equipment used to store, process or access VA information to VA in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Information Security Knowledge Service requirements and NIST 800-88. The Contractor shall send a self-certification that the data destruction requirements above have been met to the COR/CO within 30 business days of termination of the contract.
- d. All external internet connections to VA network involving VA information must be in accordance with VA Trusted Internet Connection (TIC) Reference Architecture and VA Directive and Handbook 6513, Secure External Connections and reviewed and approved by VA prior to implementation. Government-owned Contractor-operated systems, third party or business partner networks require a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).
- e. Contractor procedures shall be subject to periodic, announced, or unannounced assessments by VA officials, the OIG or a 3PAO. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above assessment to the VA COR/CO. The Contractor shall use VA's defined processes to document planned remedial actions that address identified deficiencies in information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA Information Security Knowledge Service.
- f. All major information system changes which occur in the production environment shall be reviewed by the VA to determine the impact on privacy and security of the system. Based on the review results, updates to the Authority to Operate (ATO) documentation

eDiscovery Software as a Service (SaaS) & Maintenance
VA-26-00011700

and parameters may be required to remain in compliance with VA Handbook 6500 and VA Information Security Knowledge Service requirements.

- g. The Contractor shall conduct an annual privacy and security self-assessment on all information systems and outsourced services as required. Copies of the assessment shall be provided to the COR/CO. The VA/Government reserves the right to conduct assessment using government personnel or a third-party if deemed necessary. The Contractor shall correct or mitigate any weaknesses discovered during the assessment.
- h. VA prohibits the installation and use of personally owned or Contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the Contractor OE, must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The Contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall on the non-VA owned OE. Approved Contractor OE will be subject to technical inspection at any time.
- i. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems. The system or effected component(s) need(s) to be isolated from the network. A forensic analysis needs to be conducted jointly with VA. Such issues will be remediated as quickly as practicable, but in no event longer than the timeframe specified by VA Information Security Knowledge Service. If sensitive personal information is compromised reference VA Handbook 6500.2 and Section 5, Security Incident Investigation.
- j. For cases wherein the Contractor discovers material defects or vulnerabilities impacting products and services they provide to VA, the Contractor shall develop and implement policies and procedures for disclosure to VA, as well as remediation. The Contractor shall, within 30 business days of discovery, document a summary of these vulnerabilities or defects. The documentation will include a description of the potential impact of each vulnerability and material defect, compensating security controls, mitigations, recommended corrective actions, root cause analysis and/or workarounds (i.e., monitoring). Should there exist any backdoors in the products or services they provide to VA (referring to methods for bypassing computer authentication), the Contractor shall provide the VA CO/CO written assurance they have permanently remediated these backdoors.
- k. All other vulnerabilities, including those discovered through routine scans or other assessments, will be remediated based on risk, in accordance with the remediation timelines specified by the VA Information Security Knowledge Service and/or the applicable timeframe mandated by Cybersecurity & Infrastructure Security Agency

(CISA) Binding Operational Directive (BOD) 22-01 and BOD 19-02 for Internet-accessible systems. Exceptions to this paragraph will only be granted with the approval of the COR/CO.

B8. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT AND AUDITING

- a. Should VA request it, the Contractor shall provide a copy of their (corporation's, sole proprietorship's, partnership's, limited liability company (LLC), or other business structure entity's) policies, procedures, evidence and independent report summaries related to specified cybersecurity frameworks (International Organization for Standardization (ISO), NIST Cybersecurity Framework (CSF), etc.). VA or its third-party/partner designee (if applicable) are further entitled to perform their own audits and security/penetration tests of the Contractor's IT or systems and controls, to ascertain whether the Contractor is complying with the information security, network or system requirements mandated in the agreement between VA and the Contractor.
- b. Any audits or tests of the Contractor or third-party designees/partner VA elects to carry out will commence within 30 business days of VA notification. Such audits, tests and assessments may include the following: (a): security/penetration tests which both sides agree will not unduly impact Contractor operations; (b): interviews with pertinent stakeholders and practitioners; (c): document review; and (d): technical inspections of networks and systems the Contractor uses to destroy, maintain, receive, retain, or use VA information.
- c. As part of these audits, tests and assessments, the Contractor shall provide all information requested by VA. This information includes, but is not limited to, the following: equipment lists, network or infrastructure diagrams, relevant policy documents, system logs or details on information systems accessing, transporting, or processing VA data.
- d. The Contractor and at its own expense, shall comply with any recommendations resulting from VA audits, inspections and tests. VA further retains the right to view any related security reports the Contractor has generated as part of its own security assessment. The Contractor shall also notify VA of the existence of any such security reports or other related assessments, upon completion and validation.
- e. VA appointed auditors or other government agency partners may be granted access to such documentation on a need-to-know basis and coordinated through the COR/CO. The Contractor shall comply with recommendations which result from these regulatory assessments on the part of VA regulators and associated government agency partners.

B9. CRYPTOGRAPHIC REQUIREMENT

- a. The Contractor shall document how the cryptographic system supporting the Contractor's products and/or services protect the confidentiality, data integrity, authentication and non-repudiation of devices and data flows in the underlying system.
- b. The Contractor shall use only approved cryptographic methods as defined in FIPS 140-2 (or its successor) and NIST 800-52 standards when enabling encryption on its products.
- c. The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys.
- d. The Contractor shall ensure emergency re-keying of all devices can be remotely performed within 30 business days.
- e. The Contractor shall provide or arrange for the provision of a method for updating cryptographic primitives or algorithms.

B10. PATCHING GOVERNANCE

- a. The Contractor shall provide documentation detailing the patch management, vulnerability management, mitigation and update processes (to include third-party) prior to the connection of electronic devices, assets or equipment to VA's assets. This documentation will include information regarding the following:
 - (1) The resources and technical capabilities to sustain the program or process (e.g., how the integrity of a patch is validated by VA); and.
 - (2) The approach and capability to remediate newly reported zero-day vulnerabilities for Contractor products.
- b. The Contractor shall verify and provide documentation all procured products (including third-party applications, hardware, software, operating systems, and firmware) have appropriate updates and patches installed prior to delivery to VA.
- c. The Contractor shall provide or arrange the provision of appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses for their products and services within 30 days of discovery. Updates to remediate critical or emergent vulnerabilities will be provided within seven business days of discovery. If updates cannot be made available by Contractor within these time periods, the Contractor shall submit mitigations, methods of exploit detection and/or workarounds to the COR/CO prior to the above deadlines.
- d. The Contractor shall provide or arrange for the provision of appropriate hardware, software and/or firmware updates, when those products, including open-source software, are provided to the VA, to remediate newly discovered vulnerabilities or weaknesses. Remediations of products or services provided to the VA's system

environment must be provided within 30 business days of availability from the original supplier and/or patching source. Updates to remediate critical vulnerabilities applicable to the Contractor's use of the third-party product in its system environment will be provided within seven business days of availability from the original supplier and/or patching source. If applicable third-party updates cannot be integrated, tested and made available by Contractor within these time periods, mitigations and/or workarounds will be provided to the COR/CO before the above deadlines.

B11. DATA CENTER PROVISIONS

- a. The Contractor shall ensure the VA network is accessed by in accordance with VA Directive 6500 and IAM security processes specified in the VA Information Security Knowledge Service.
- b. The Contractor shall ensure network infrastructure and data availability in accordance with VA information system business continuity procedures specified in the VA Information Security Knowledge Service.
- c. The Contractor shall ensure any connections to the internet or other external networks for information systems occur through managed interfaces utilizing VA approved boundary protection devices (e.g., internet proxies, gateways, routers, firewalls, guards or encrypted tunnels).
- d. The Contractor shall encrypt all traffic across the segment of the Wide Area Network (WAN) it manages and no unencrypted Out of Band (OOB) Internet Protocol (IP) traffic will traverse the network.
- e. The Contractor shall ensure tunnel endpoints are routable addresses at each VA operating site.
- f. The Contractor shall secure access from Local Area Networks (LANs) at co-located sites in accordance with VA TIC Reference Architecture, VA Directive and Handbook 6513, and MOU/ISA process specified in the VA Information Security Knowledge Service.